UTMSTACK OBSERVATORY

Security Assessment

Version 1.16.0 · 18–19 October 2026

UTMStack Observatory — Security Assessment

Product	UTMStack Observatory
Versions	Assessed: 1.14.2 (deployed) and 1.15.0 (source). Retested after fixes: **1.16.0**
Dates	18–19 October 2026
Type	White-box review: automated scanning, manual source review, and live tests against isolated local instances
Performed by	AI-assisted assessment (Claude, Anthropic) for the product owner. This is not a third-party penetration test.

1. Executive summary

UTMStack Observatory is a read-only dashboard that reads a UTMStack SIEM's OpenSearch data and presents it to operators. The assessment combined six automated scanners with a line-by-line review of the server, front end, container image and installer, plus targeted live tests.

No critical or high-severity issue was found. An unauthenticated attacker cannot read data, change settings or run code. The core controls are sound. Login checks resist timing attacks and lock out repeated guessing. Every change request is protected against cross-site forgery. All attacker-influenced text is escaped before display. Database queries are built safely. Outbound lookups accept only public IP addresses. The container runs unprivileged on a read-only file system.

The assessment raised **18 findings**: 7 medium, 9 low and 2 informational. In version 1.16.0:

Status	Count
Fixed	12
Mitigated or partly fixed (the remaining part is an accepted risk)	5
Open (recommendation, accepted for this release)	1

The most significant issues, all now fixed:

- A slow-connection attack could make the dashboard unavailable before login (OBS-02).
- The Content Security Policy allowed inline scripts, which removes the browser's safety net against cross-site scripting (OBS-03). The bundled map library also has a known cross-site scripting flaw (OBS-04).
- Anyone signed in could change the password, API keys or support link without re-entering the password, and nothing was logged (OBS-05). A password changed in the dashboard could not be revoked by the installer (OBS-06).
- When run without a password, the dashboard could be reached through DNS rebinding (OBS-07).
- New installs used plain HTTP by default, so the password crossed the network unencrypted (OBS-01).

The main residual risks are:

- The dashboard reads OpenSearch with UTMStack's administrator account (OBS-08).
- Existing installs stay on plain HTTP until they are reinstalled with `--tls`.
- Unfixed Debian base-image CVEs (no fixes available upstream).

Overall rating	
Before fixes	**Moderate**: no direct compromise path, but weak availability and defence in depth
After fixes (1.16.0)	**Low**

2. Scope

In scope

- `app/server.py`: HTTP server, authentication, API, OpenSearch client
- `app/index.html`, `app/app.js`, `app/layout.js`: single-page user interface
- `app/settings_store.py`, `app/layout_store.py`, `app/reports.py`, `app/geoip.py`, `app/healthcheck.py`, `app/demo.py`
- `Dockerfile`, `install.sh`, `requirements.txt`
- Vendored MapLibre GL JS 4.7.1
- The git history, for leaked secrets

Out of scope

- UTMStack itself, OpenSearch, and the host operating system
- Third-party services the dashboard calls (rdap.org, AbuseIPDB, VirusTotal, proxycheck.io, OpenFreeMap)
- Denial-of-service testing against the production host. All load tests used local instances.

Test environments

- Local instances in demo mode (synthetic data, Python 3.9 and 3.12).
- A locally built container image.
- Read-only, rate-limited scans (nmap, nikto) of the deployed instance's dashboard port, before any fixes.

3. Method and tools

Tool	Version	Used for
Trivy	0.69.3 (vulnerability DB of 13 Oct 2026)	Container image and file system: OS and library vulnerabilities, secrets, Dockerfile misconfiguration
Bandit	1.8.6	Python security lint
Semgrep	1.136.0 (`p/python`, `p/javascript`, `p/secrets`)	Static analysis
pip-audit	2.9.0 / 2.10.1	Python dependency vulnerabilities (Python 3.12 resolution, as in the image)

Tool	Version	Used for
nmap, nikto	7.99, 2.6.0	Service fingerprint and HTTP header checks (deployed instance, authenticated, gentle)
OSV database	—	Vendored MapLibre 4.7.1 advisories
curl, custom Python and Playwright scripts	—	Live tests: authentication, CSRF, CSP, XSS payloads, slow connections, DNS-rebinding Host headers, lookup URL construction

Severity uses the CVSS 3.1 base metrics as a guide, adjusted for how the product is deployed: a monitoring view on a trusted network next to the SIEM, behind a login.

4. Findings summary

ID	Title	Severity	Status in 1.16.0
OBS-01	Plain HTTP by default while Basic-auth credentials ride on every request	Medium	**Fixed for new installs** (TLS by default); existing installs keep their setting
OBS-02	Pre-auth slow-connection denial of service	Medium	**Fixed**
OBS-03	CSP allows `script-src 'unsafe-inline'`	Medium	**Fixed**
OBS-04	Vendored MapLibre GL JS 4.7.1 attribution XSS (GHSA-jrc7-96c5-q579)	Medium	**Mitigated** (vulnerable control removed; library upgrade planned)
OBS-05	Any signed-in user can change password, keys and support link without re-auth; no audit log	Medium	**Fixed** (re-auth plus audit log); separate viewer role on roadmap
OBS-06	Password saved in the UI cannot be revoked with `install.sh password`	Medium	**Fixed**
OBS-07	DNS rebinding against password-less localhost mode	Medium	**Fixed**
OBS-08	Dashboard uses UTMStack's OpenSearch administrator account	Low	**Open**: recommendation, accepted
OBS-09	OpenSearch TLS certificate not verified	Low	**Mitigated** (`OS_CA_FILE` option; default unchanged for UTMStack's internal certificate)
OBS-10	Dashboard password stored in clear text in `settings.json`	Low	**Fixed** (PBKDF2-SHA256, 600,000 iterations); API keys stay recoverable by design
OBS-11	Lockout is per IP only; 8-character minimum password	Low	**Partly fixed** (12-character minimum); proxy-aware limits on roadmap
OBS-12	IPv6 zone IDs can inject query parameters into lookup URLs	Low	**Fixed**
OBS-13	Some third-party numbers reach `innerHTML` unescaped	Low	**Fixed**

ID	Title	Severity	Status in 1.16.0
OBS-14	Python's default error pages and HEAD/OPTIONS skip security headers	Low	**Fixed**
OBS-15	Installer exposes secrets on command lines and mounts them world-readable	Low	**Partly fixed**
OBS-16	Supply chain and image hygiene	Low	**Partly fixed**
OBS-17	Internal error text returned to the browser	Info	**Fixed**
OBS-18	Code-hygiene notes (shell string, query operators, CSRF content type)	Info	**Fixed** (two of three; the third is harmless)

5. Detailed findings

OBS-01 — Plain HTTP by default · Medium · Fixed for new installs

Description. The installer enabled HTTPS only with `--tls`, and Docker Swarm publishes the port on every interface. The browser sends the HTTP Basic credentials with every poll, every 4 to 10 seconds. Anyone who can watch the network path can read the administrator password.

Fix (1.16.0).

- New installs now default to HTTPS with a generated self-signed certificate. `--no-tls` opts out.
- Existing installs keep their saved choice, so an upgrade never changes a working address without warning, and the installer still prints a warning for HTTP.
- HSTS is sent whenever TLS is on.

Recommendation. For production, put the dashboard behind a reverse proxy with a trusted certificate, or reinstall existing deployments with `--tls`.

OBS-02 — Pre-auth slow-connection denial of service · Medium · Fixed

Description. The socket timeout applied to each read, not to the whole request, and the number of connections was unlimited by default. A client that sent one header line every 5 seconds held a server thread indefinitely. In the test, 200 such clients pinned 205 threads. With a connection cap configured, 20 slow clients blocked every legitimate request. Separately, the listen backlog of 5 reset bursts of ordinary parallel connections.

Fix.

- A watchdog closes any connection that has not delivered a complete request line and headers within `HEADER_DEADLINE_S` (default 10 s).
- Defaults are now `MAX_CONNECTIONS=64` and `MAX_CONNECTIONS_PER_IP=32`.
- The listen backlog is 128.

Retest.

- `test_obs02_slow_headers_are_cut_off_at_the_deadline`: a trickling client is cut off within the deadline.
- `test_obs02_one_address_cannot_take_every_connection`: a single address cannot use every connection.

OBS-03 — CSP allowed inline script · Medium · Fixed

Description. The dashboard's whole script was inline, so the policy needed `script-src 'unsafe-inline'`. That also allows inline event-handler attributes, so any HTML-injection bug would become script execution.

Fix.

- The script moved to `/app.js`.
- The policy is now `default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; object-src 'none'; frame-ancestors 'none'; base-uri 'none'; form-action 'none'`, plus image and connect sources for the map tile host.
- Inline styles remain allowed. They cannot run script.

Retest.

- `test_obs03_csp_has_no_inline_script_and_the_page_has_no_inline_script`.
- In a browser: no CSP violations, and the map, drawers and settings all work.

OBS-04 — MapLibre GL JS 4.7.1 attribution XSS · Medium · Mitigated

Description. GHSA-jrc7-96c5-q579 (fixed in MapLibre 6.4.1). MapLibre's attribution control writes the tile provider's attribution HTML with `innerHTML`, and its sanitiser lets event-handler payloads through. Exploiting it needs a compromised or malicious tile provider (`tiles.openfreemap.org`).

Fix.

- The MapLibre attribution control is no longer used.
- The credit is a fixed text link created with `textContent`.
- The style's own attribution strings are stripped before use.
- With OBS-03 fixed, an injected handler would be blocked by the CSP anyway.

Remaining. Upgrade to MapLibre 6.4.1 or later in a later release. It is a major version and needs map regression testing.

OBS-05 — Settings changes without re-authentication; no audit trail · Medium · Fixed

Description. `PUT /api/settings` needed only the session's Basic credentials. A screen left signed in, such as a NOC wall, let anyone change the password (locking out the owner), replace the reputation API keys, or point the support contact at a phishing site. No change was logged.

Fix.

- Changing the user name, password, either API key or the support contact now requires the **current password**. It is checked under the same lockout as logins.
- Every settings and shared-layout write is logged with the client address and the names of the changed keys, never the values.
- Harmless settings, such as map locations and the report hour, do not need it.

Retest.

- `test_obs05_sensitive_settings_need_the_current_password`.
- In a browser: the Settings panel refuses without the current password and saves with it.

Roadmap. A separate read-only viewer login for wall screens, with name anonymisation enforced on the server.

OBS-06 — Installer could not revoke a UI-set password · Medium · Fixed

Description. A password saved in the Settings panel took precedence over the installer's Docker secret, and `install.sh password` never touched the saved one. After a suspected compromise, the owner could not revoke a password an attacker had set.

Fix.

- `install.sh password` (and `--password`, `--password-file`, `--user`, `--abuseipdb-key`, `--virustotal-key`) now removes the matching Settings-panel override from the data volume, so the installer's value takes effect.
- `install.sh password` with no argument now really generates a new password.

Retest. `test_obs06_installer_can_clear_a_password_saved_in_settings`.

OBS-07 — DNS rebinding in password-less mode · Medium · Fixed

Description. Without a password, the server binds to 127.0.0.1 and lets every request through. The CSRF check compared `Origin` with the request's own `Host` header, which a DNS-rebinding page controls. A malicious web page visited by the operator could read SIEM data or set a password.

Fix. With no login configured, only `Host` values of `localhost`, `127.0.0.1` or `::1` (plus any in `ALLOWED_HOSTS`) are answered. Others get 403.

Retest. `test_obs07_dns_rebinding_host_is_refused`.

OBS-08 — OpenSearch administrator account · Low · Open (accepted)

Description. The installer reuses the credentials of UTMStack's backend, which is the OpenSearch administrator. No code path writes to OpenSearch, but any future code-execution or request-forgery bug would carry full SIEM rights, including deleting evidence. The `docker exec` transport for bare-metal installs needs password-less `sudo docker`, which is root-equivalent on the host.

Recommendation. Have the installer create a read-only OpenSearch role (`read` and `view_index_metadata` on `v11-*`, plus `cluster:monitor/*`) and a dedicated user. Use the Swarm transport rather than `docker exec`.

Accepted for this release because UTMStack's own security plugin setup varies by version and needs testing on each.

OBS-09 — OpenSearch certificate not verified · Low · Mitigated

Description. All OpenSearch calls skipped certificate verification. The traffic stays inside the Swarm overlay network, but it carries the administrator credentials.

Fix. New `OS_CA_FILE` setting: when it is set, the certificate is verified against that CA (hostname check on by default; `OS_CHECK_HOSTNAME=0` turns it off for certificates issued to an IP address). The default stays unverified because UTMStack ships its own internal self-signed certificate.

The container health check (`healthcheck.py`) also skips verification, but it only connects to 127.0.0.1 inside the container. Accepted.

OBS-10 — Password stored in clear text · Low · Fixed

Description. A password saved from the Settings panel was written as plain text to `/data/settings.json`, which is mode 0600 inside the data volume.

Fix.

- New passwords are stored as PBKDF2-SHA256 with 600,000 iterations and a random salt.
- Clear-text passwords left by earlier versions are converted at start-up.
- A short in-memory cache of successful checks keeps the dashboard's polling cheap.

API keys must be sent to the providers, so they stay recoverable, and backups of `/data` contain them. This is documented.

Retest. `test_obs10_password_saved_from_settings_is_hashed`.

OBS-11 — Per-IP lockout only · Low · Partly fixed

Description. The lockout (5 failures, then 15 minutes) correctly ignores the spoofable `X-Forwarded-For` header, but it is per address only. Behind a reverse proxy or shared NAT, one person can lock out everyone, and there is no global limit against distributed guessing. The minimum password length was 8.

Fix.

- New passwords need at least 12 characters (`test_obs11_new_passwords_need_twelve_characters`).
- Installer-generated passwords are 20 random characters.

Roadmap. Trusted-proxy support and a global failure budget.

OBS-12 — Lookup URLs built from unencoded IP strings · Low · Fixed

Description. Python accepts IPv6 zone IDs such as `2606:4700::1%x&verbose#` and still reports them as global, so a signed-in API caller could add query parameters to AbuseIPDB, VirusTotal and RDAP requests. The

destination hosts were fixed, so this was not server-side request forgery.

Fix.

- Addresses with a zone ID are refused.
- Lookup URLs are built with `urlencode` and `quote`, including the proxycheck.io lookup in `geoip.py`.

Retest. `test_obs12_ip_with_a_zone_id_is_refused`.

OBS-13 — Unescaped numbers in HTML · Low · Fixed

Description.

- The AbuseIPDB score and the VirusTotal counts were inserted into HTML unescaped.
- So were the raw geolocation fields of alert documents, in `data-lat` and `data-lon`.

A malicious upstream response or a crafted alert could inject markup.

Fix.

- The server converts these values to numbers, or to `null` when that fails.
- The client escapes them as well.

OBS-14 — Default error pages without security headers · Low · Fixed

Description.

- `HEAD`, `OPTIONS`, `DELETE` and malformed request lines got Python's built-in error page, without CSP, framing or `nosniff` headers.
- `Permissions-Policy`, `Cross-Origin-Opener-Policy` and `Cross-Origin-Resource-Policy` were missing everywhere.

Fix.

- Every response, including errors, now goes through one header path.
- `HEAD` is supported and other methods get 405 with an `Allow` header.
- The three missing headers are added.
- `Content-Length` is now always sent.

Retest. `test_obs14_head_and_unknown_methods_carry_the_security_headers`.

OBS-15 — Installer secret handling · Low · Partly fixed

Fixed.

- Docker secrets are mounted `uid=10001, mode=0400`; before, they were world-readable (0444).
- The installer's own login check passes credentials to curl on standard input, not on its command line.
- New `--password-file` option.
- The password is printed only when it was generated.

Accepted. `--abuseipdb-key` and `--virustotal-key` are still command-line options. The Settings panel is the recommended way to enter keys.

OBS-16 — Supply chain and image hygiene · Low · Partly fixed

Fixed.

- `pillow>=12.3` is pinned (it comes in through fpdf2; pip-audit flagged older versions).
- The image applies Debian security updates at build time.
- pip is removed from the runtime image; it carried 6 CVEs.

Current state. pip-audit reports no known vulnerabilities. Trivy reports **0 vulnerabilities with an available fix** and 0 misconfigurations. 44 high and 58 medium Debian CVEs remain, none with a fix released (mostly util-linux, ncurses and perl-base, which the dashboard does not use directly).

Remaining.

- Pin the base image by digest and rebuild monthly.
- Install with `--require-hashes`.
- Run outside Swarm only with `--read-only --cap-drop ALL --security-opt no-new-privileges`; this is documented.

OBS-17 — Internal error text returned to the client · Info · Fixed

The API now returns a short message and a reference ID, for example `internal error (ref 3fa9c1)`, and logs the detail on the server under that ID (`test_obs17_internal_errors_are_not_echoed`).

OBS-18 — Code hygiene · Info · Fixed (two of three)

- **Fixed.** The `docker exec` transport now refuses any OpenSearch path outside a strict character set before building its shell command.
- **Fixed.** Free-text alert search is limited to cheap query operators: no prefix, fuzzy or wildcard searches.
- **Left as is.** The CSRF check's `Content-Type` prefix match. It is harmless, because the required custom header forces a CORS preflight, which the server refuses.

6. Controls verified as sound

Authentication

- Basic credentials are parsed fail-closed.
- User name and password are compared in constant time, and both comparisons always run.
- The lockout is atomic, counts only requests that carry credentials, applies even to a correct password while locked, and answers 429 with `Retry-After`. The client address comes from the socket, never from `X-Forwarded-For`.
- Only `/healthz` (body `ok`) is reachable without login.
- The server refuses to listen on a network address without a password unless `ALLOW_NO_AUTH=1` is set.

CSRF. Exactly three routes change state: `PUT /api/layout`, `PUT /api/settings` and `POST /api/reports/generate`. Each requires a JSON body, the `X-Observatory: 1` header and a matching `Origin`. Each of these was refused in tests: missing header, cross-site origin, `Origin: null`, and look-alike origins.

Cross-site scripting

- About 60 `innerHTML` sinks, covering alerts, raw log lines, WHOIS, reputation, the map ticker, support, settings and layout names, all escape attacker-influenced text.
- XSS payloads in every settings field rendered as text in a real browser.
- The support URL is forced to `http(s)`.

Injection

- User input reaches OpenSearch only as JSON values (`term`, `ids`, allowlisted enums and clamped numbers). No `query_string` is used.
- Report downloads match a strict file-name pattern inside a fixed directory.
- Static files come from a fixed list. Path traversal probes return 404.

Outbound calls

- Lookups go only to fixed hosts and only for public addresses.
- Private, loopback, link-local, CGNAT and IPv4-mapped addresses are refused.
- Every call verifies TLS, has a timeout and reads a capped amount.

Secrets

- Every secret can come from a file (Docker secrets).
- The `docker exec` transport passes the OpenSearch password on standard input.
- The settings API returns only "configured" flags for secrets.
- No secret is logged.
- The git history contains only test fixtures.

Container

- Runs as non-root user 10001.
- Under the installer: read-only root file system, all capabilities dropped, 512 MB memory and 1 CPU limits, tmpfs `/tmp`, and the host file system mounted read-only.
- The TLS listener requires TLS 1.2 or later and does each handshake in its own thread.

Resource bounds. Every cache is capped: WHOIS and reputation (500 entries), map queries (200), the login table (about 10,000) and the online GeoIP queue (500, with a daily budget).

Vendored library. The MapLibre files are byte-identical to the npm 4.7.1 release, so they have not been tampered with.

7. Retest results (1.16.0)

Check	Result
Unit and integration tests	118 Python tests and 13 JavaScript tests pass on Python 3.9 and 3.12, including 11 new regression tests for these findings (`tests/test_security_fixes.py`)
Long-standing flaky lockout test	Root cause found (listen backlog of 5 resetting parallel connections); now stable over repeated runs
pip-audit (Python 3.12)	No known vulnerabilities
Trivy image	0 fixable vulnerabilities, 0 secrets, 0 misconfigurations
Bandit	Remaining items reviewed and accepted: fixed-scheme `urlopen` calls, the localhost health check's unverified TLS, the intentional bind to all interfaces, and the reviewed `subprocess` use
Semgrep	1 finding: the localhost health check's unverified TLS context (accepted, see OBS-09)
Browser check	No CSP violations or script errors; map, filters, drawers and settings work; the Settings panel requires the current password for sensitive changes
Container	The image builds and starts read-only with all capabilities dropped; the headers are as documented

8. Recommendations for the next release

1. A read-only OpenSearch role and user created by the installer (OBS-08).
2. MapLibre GL JS 6.4.1 or later (OBS-04).
3. A read-only viewer login for wall screens, with anonymisation enforced on the server (OBS-05).
4. Trusted-proxy support and a global login-failure budget (OBS-11).
5. A base image pinned by digest, hash-locked dependencies and a monthly rebuild (OBS-16).
6. A reverse-proxy deployment guide with a trusted certificate, and upgrading existing installs to TLS (OBS-01).

Appendix A — Deployment hardening checklist

- [ ] HTTPS on (`--tls`, or a reverse proxy with a trusted certificate)
- [ ] Port 8765 restricted with the host firewall (`DOCKER-USER` chain) to the admin network or VPN
- [ ] Installer-generated password kept, or a new one of at least 12 characters
- [ ] Settings-panel API keys entered only by administrators; `/data` backups treated as sensitive
- [ ] Wall screens on a dedicated, locked-down kiosk account
- [ ] Logs (`install.sh logs`) collected; look for `audit:` and `login:` lines
- [ ] Image rebuilt monthly (`sudo ./install.sh`) to pick up base-image security fixes
- [ ] Demo mode (`DEMO=1`) never set on a production install